第十五讲 课堂教学实录视频讲稿

> *课程：Java Web应用开发 (Java Web Application Development)*
> *赛道：人工智能赛道*
> *课堂主题：用户认证与权限控制 (Authentication & Authorization)*
> *建议时长：45分钟*
> *授课方式：双语教学（中文讲解 + 英文关键术语）*
> *教学场所：多媒体机房（每人一机）*
> ***AI工具：WebDev助教 / WebSec挑战 / TeamCoach / Code Review Battle***

课前准备清单

录制前确认以下事项全部就绪：

1. **投影系统**：Marp课件已全屏投影，可随时切换到浏览器
2. **WebDev助教后台**：教师仪表盘已登录，学情数据面板可展示（或备用截图已就绪）
3. **TeamCoach**：本周团队周报已生成，页面已打开备用（或备用截图已就绪）
4. **课程作业管理系统（交互演示版）**：浏览器已打开 `第十五讲交互演示/index.html`，可切换问题版/修复版/代码对比三个页面
    - 问题版演示：`demo-problem.html`（演示安全缺陷）
    - 修复版演示：`demo-fixed.html`（演示修复后的正确行为）
    - 代码对比：`code-compare.html`（逐缺陷代码diff + 测试验证表）
5. **WebSec挑战平台**：第15讲关卡已配置，第1、3关课前已完成，第2关为课堂重点；实时数据大屏可展示（或备用截图已就绪）
6. **Code Review Battle平台**：对战已创建，待审查代码已加载（或备用截图已就绪）
7. **备用截图**：所有AI平台的关键页面截图已保存，防止网络故障
8. **学生分组**：A/B/C三组已提前分好，学生已知分组
9. **摄像机位**：主机位对准教师+投影，辅机位可拍学生区域
10. **四维工具确认**：确认本讲涉及的AI融合创新工具全部可用或有截图备份——智能助教（学情数据）、编程挑战（闯关平台）、团队教练（周报）、人机对抗（对战平台）

阶段一：数据驱动导入（0:00-5:00，5分钟）

[0:00-0:30] 开场问候与课题引入

画面：课件封面页——"用户认证与权限控制 Authentication and Authorization"；随后快速翻至"教学目标"页

教师动作：站在讲台中央，面向学生，自然微笑

教师台词：

> *同学们好！Welcome to Lecture 15. 今天我们的主题是——用户认证与权限控制，英文叫Authentication and Authorization。*
>
> *大家看一下教学目标——知识层面我们要区分认证和授权、掌握Session机制和RBAC；能力层面要能实现登录登出和会话管理，还要能借助AI工具做安全漏洞识别和代码审查。*
>
> *在正式开始之前呢，我想先给大家看一组数据。这组数据，来自于我们课程的AI助教后台。*

学生活动：安静就坐，进入课堂状态

AI工具操作：无

拍摄提示：中景拍摄教师正面，背景可见投影画面。教师说"看一组数据"时，可略微转身指向屏幕。

预计字数：约100字，用时30秒

[0:30-1:30] WebDev助教 · 课前学情数据展示

画面：切换到WebDev助教教师仪表盘——课前学情数据面板（提问频次热力图、TOP 3热点问题、知识薄弱点分析）

教师动作：走到屏幕一侧，侧身面向学生，用手指向屏幕上的数据

教师台词：

> *大家看，这是WebDev助教——我们课程的AI智能体——在课前三天自动采集的数据。*
>
> *全班58人中，有42位同学在课前向智能体提过问题，覆盖率达到72%，这个参与度非常不错。*
>
> *我们看热点问题TOP 3：排名第一的是"Session过期后如何处理"，有23位同学问到了这个问题；第二是"Filter如何判断用户角色"，18人；第三是"Cookie和Session的安全区别"，15人。*
>
> *（停顿，看向学生）有同学的问题上榜了吗？*
>
> *另外，智能体分析发现一个很普遍的认知偏差——很多同学混淆了 `invalidate()` 和 `removeAttribute()`。这两个方法看起来都能"退出登录"，但效果完全不一样。*
>
> *根据这些数据，我调整了今天的教学重点——强化Session安全管理和角色权限控制。这就是数据驱动的教学决策。*

学生活动：观看数据面板，部分学生会心一笑（发现自己的问题上榜），个别学生小声交流

AI工具操作：【WebDev助教】展示教师仪表盘 → 课前学情数据面板 → 提问频次热力图 → TOP 3热点问题

拍摄提示：画面以屏幕为主，教师在侧面指点；当教师问"有同学上榜了吗"时，切一个学生区域的反应镜头。

预计字数：约200字，用时60秒

[1:30-2:30] TeamCoach · 团队项目周报展示

画面：切换到TeamCoach周报页面——贡献度对比图、团队风险预警

教师动作：保持在屏幕一侧，语气略严肃但不苛责

教师台词：

> *接下来看另一组数据。这是TeamCoach——我们的团队项目AI教练——生成的上周报告。*

> *几个需要关注的问题：第3组，Service层目前无人负责，如果继续下去，到集成阶段很可能成为瓶颈。第5组，有同学连续两周只修改了README文件，代码贡献明显不足。*
>
> *（语气转缓和）这些数据不是要批评谁，而是帮助我们尽早发现问题。TeamCoach基于你们Git仓库的真实提交记录做分析，数据是客观的。*
>
> *还有一个值得注意的数据：全班目前的测试覆盖率是——0%。没有任何一个组写了测试代码。今天我们的攻防闯关环节，会让大家深刻体会到"测试"和"验证"的价值。*

学生活动：认真听取周报数据，相关团队成员互相对视，意识到改进需要

AI工具操作：【TeamCoach】展示团队周报页面 → 贡献度对比图 → 风险预警列表

拍摄提示：以屏幕为主，教师指向具体数据点。注意不要给被点名团队的学生特写镜头，保护学生隐私。

预计字数：约180字，用时60秒

[2:30-4:00] 现场演示权限漏洞

画面：切换到浏览器——打开 `demo-problem.html`（课程作业管理系统交互演示·问题版）

教师动作：走到教师机前，开始操作演示，边操作边讲解

教师台词：

> *好，数据看完了。现在我们来看一个真实的系统。这是我们课程一直在用的作业管理系统。*
>
> *我现在打开它的交互演示版——问题版。这个系统完整模拟了真实Java Web应用的Servlet、Filter、Session行为，方便大家直接在浏览器中看到效果。*
>
> *首先，我用管理员账号登录。（选择admin / admin123，点击登录）*
>
> *大家看，管理员登录后，首页导航栏有"管理后台"入口，点进去可以看到全班成绩、系统管理等功能。这是正常的。*
>
> *（回到登录页）现在，我换普通用户Tom。（选择tom / tom123，点击登录）*

> *Tom是一个普通学生。但大家注意看——（指向屏幕）导航栏上也出现了"管理后台"入口！*
>
> *我们点一下试试.....（点击"管理后台"）*
>
> *看到了吗？Tom——一个普通学生——成功进入了管理后台！他可以查看成绩、修改成绩、甚至删除提交。Filter只检查了"是否登录"，没有检查"是否是ADMIN"。这就是越权访问的根源。*

学生活动：观察操作演示，部分学生发出惊讶声

AI工具操作：无（使用交互演示HTML页面）

拍摄提示：屏幕录制为主，确保以下画面清晰可见：(1) admin登录后的正常管理后台；(2) tom登录后导航栏出现"管理后台"；(3) tom成功进入管理后台的页面。教师手指点击和指向的动作要拍到。

预计字数：约220字，用时90秒

[4:00-5:00] 抛出核心问题

画面：课件大字投影——"能登录 ≠ 能安全控制访问"

教师动作：从教师机旁走回讲台中央，面向全班，双手自然展开

教师台词：

> *（切回课件，投影核心问题）*
>
> *这就是我们今天要解决的核心问题——*
>
> *"如果一个普通用户登录后也能进入管理后台，这个系统安全吗？"*
>
> *很明显，答案是不安全。但问题出在哪？Tom的身份验证通过了——他确实是一个合法用户。那问题到底是什么？*
>
> *（停顿，扫视全班）有同学能回答吗？*
>
> *（等待1-2秒，如有学生举手，请其回答；如无人回答，自行衔接）*

> *对，这里有两个概念需要区分：Authentication——认证，回答的是"你是谁"；Authorization——授权，回答的是"你能做什么"。Tom通过了认证，但系统没有做授权检查。能登录，不等于拥有所有权限。*
>
> *今天这45分钟，我们就要彻底解决这个问题。*

学生活动：思考问题，部分学生尝试回答

AI工具操作：无

拍摄提示：教师正面中景，表情认真。问"有同学能回答吗"时切到学生区域。如果有学生回答，给该学生一个镜头。

预计字数：约180字，用时60秒

阶段二：安全攻防闯关（5:00-16:00，11分钟）

[5:00-7:00] WebSec挑战平台 · 规则说明

画面：切换到WebSec挑战平台——第15讲关卡总览页面（5个关卡列表 + 排行榜），重点突出第1、3关标记为"课前完成"

教师动作：站在屏幕旁，用手指逐一指向各关卡

教师台词：

> *好，接下来我们进入今天最刺激的环节——安全攻防闯关！*
>
> *大家看屏幕。这是我们自主研发的WebSec挑战平台。今天第15讲一共有5个安全关卡：*
>
> *（逐一指向）第1关SQL注入和第3关Session安全——大家在课前已经通过平台完成了，数据显示大部分同学都顺利通关了，非常好。*
>
> *今天课堂上，我们聚焦第2关——越权访问。这一关和我们刚才看到的Tom进入管理后台的问题直接相关，考的就是Filter权限检查。第4关XSS和第5关综合BOSS关留到课后完成。*

> *规则是这样的——（语气加重）每个人的题目都不一样！这些漏洞代码是AI自动生成的——同样的知识点、不同的业务场景、不同的漏洞位置，实现一人一题。你需要做三件事：找到漏洞、写出修复代码、提交后平台自动测试。通过了就过关，排行榜实时更新。*
>
> *大家现在打开平台，用你们的学号登录。聚焦第2关——越权访问。计时现在开始！*

学生活动：打开WebSec挑战平台，登录，开始闯关

AI工具操作：【WebSec挑战】展示平台首页 → 关卡列表（第1、3关已标记完成）→ 排行榜

拍摄提示：先拍屏幕上的平台界面全景（确保"课前完成"标记可见），然后在教师说"计时现在开始"时，切到学生区域，拍学生纷纷打开电脑开始操作的画面。

预计字数：约230字，用时120秒

[7:00-12:00] 学生闯关 + 教师巡视

画面：投影切换到WebSec挑战平台实时数据大屏（第2关通过率、平均用时、排行榜实时滚动）

教师动作：离开讲台，在教室中走动巡视，不时停下来看学生屏幕，偶尔低声指导

教师台词：

> *（走到学生中间，观察进展，2分钟后开始自然穿插以下话语）*
>
> *（路过A区学生时）第2关在分析了？注意看漏洞代码里Servlet对Session的检查——它到底检查了什么？遗漏了什么？*
>
> *（路过B区学生时）遇到困难了？没关系，想想我们刚才看到的那个Tom进后台的例子——问题出在哪一层？Filter有没有检查角色？*
>
> *（路过C区学生时）做得不错。如果你卡住了，可以随时向WebDev助教提问，但注意——智能体给你的是提示，不是答案，最终的修复代码需要你自己写。*
>
> *（走回讲台，看数据大屏）大家继续，排行榜上已经有同学通关了！*

学生活动：专注在WebSec挑战平台上闯关，分析AI生成的越权访问漏洞代码，编写修复方案，提交测试。部分学生遇到困难时向WebDev助教提问。

AI工具操作：【WebSec挑战】学生在平台上闯关；【WebDev助教】部分学生遇到困难时向智能体提问获取提示

拍摄提示：（重要！）这5分钟要拍到以下画面——(1) 学生专注操作电脑的全景/中景；(2) 学生屏幕上WebSec平台的第2关漏洞代码界面特写；(3) 教师在学生中间走动指导的跟拍；(4) 投影上实时数据大屏的排行榜变化。辅机位拍学生，主机位拍数据大屏。

预计字数：约150字（断续说出），用时300秒

[12:00-14:00] 数据大屏分析 + 暂停闯关讲解

画面：投影——WebSec挑战实时数据大屏，重点突出第2关通过率数据

教师动作：回到讲台，面向全班，语气从观察转为决策

教师台词：

> *好，同学们，我们先暂停一下。请大家抬头看屏幕。*
>
> *我看一下实时数据大屏——第2关，越权访问，通过率只有38%，平均用时已经4.5分钟了。很多同学在这一关反复提交，始终无法通过。*
>
> *这个数据告诉我，第2关的核心知识点——Filter角色检查——是大家的共性薄弱点。所以我决定暂停闯关，先进入核心概念的讲解，帮大家建立完整的知识框架，然后再回来继续挑战。*
>
> *（面向镜头自然补充）这就是数据驱动的即时干预——我不是按预设的教学节奏一直往前走，而是根据学生的实际表现来调整教学，在学生最需要的时候讲最关键的内容。*

学生活动：停下手中操作，抬头看屏幕，准备听讲

AI工具操作：【WebSec挑战】展示实时数据大屏 → 第2关通过率标红/预警

拍摄提示：先拍数据大屏全景（确保通过率数字清晰），然后切教师正面中景讲解。教师说"数据驱动的即时干预"时，可稍微面向镜头，这是展示教学理念的关键时刻。

预计字数：约170字，用时70秒（含停顿和等待学生安静）

[14:00-16:00] 继续闯关 + 收尾

画面：投影保持实时数据大屏

教师动作：让学生继续闯关，教师在教室中走动观察

教师台词：

> *好，核心概念讲完之后我们会回到闯关。现在大家先把闯关暂时放下，我们进入今天最关键的知识讲解环节。带着你们在第2关遇到的困难来听讲，效果会更好。*
>
> *当然，如果有同学觉得自己已经想通了，可以继续挑战。但我建议大多数同学先跟我走一遍核心概念。*

学生活动：部分学生暂停闯关准备听讲，个别已通关学生继续挑战

AI工具操作：【WebSec挑战】数据大屏保持展示

拍摄提示：过渡镜头，教师与学生交互的自然画面。

预计字数：约100字，用时120秒

阶段三：核心概念精讲（16:00-24:00，8分钟）

[16:00-17:00] 认证与授权概念对比

画面：课件——"认证与授权"页面，左右分栏对比 Authentication 和 Authorization

教师动作：站在讲台前，面向全班，配合手势分别指向左右两栏

教师台词：

> *好，同学们，我们来正式梳理两个最核心的概念。*
>
> *左边——认证，Authentication，回答的是"你是谁？"用户提供用户名和密码，系统验证身份，确认你确实是张三而不是别人。打个比方，这就像进大楼时出示身份证。*

> *右边——授权，Authorization，回答的是"你能做什么？"系统检查你的角色和权限，判断你是否有权访问某个资源。就像你的门禁卡——虽然你能进大楼，但不是每层每间办公室你都能进。*
>
> *记住这个顺序：先认证，后授权。核心原则是——登录成功不等于拥有所有权限。这就是Tom能进管理后台的根本原因——系统做了认证，但忘了授权。*

学生活动：认真听讲，对照刚才的闯关经验理解概念

AI工具操作：无

拍摄提示：教师正面中景，手势分别指向左右两栏。讲到"先认证后授权"时语气加重。

预计字数：约180字，用时60秒

[17:00-18:30] Session认证完整流程

画面：课件——"Session认证完整流程"页面，展示四个组件协同工作的流程和职责表

教师动作：站在讲台前，用手指依次指向流程步骤

教师台词：

> *了解了概念之后，我们看完整的Session认证流程——四个组件是如何协同工作的。*
>
> *第一步，用户提交登录表单；第二步，LoginServlet验证用户名和密码；第三步，验证通过后，创建Session，把User对象存进去；第四步，后续每次请求，Filter拦截检查角色；第五步，角色匹配就放行，不匹配就返回403。*
>
> *大家看右边的职责表：LoginServlet负责认证——验证身份；Session负责状态管理——维持登录态；Filter负责授权——拦截检查权限；JSP负责展示——按角色渲染界面。每个组件只做一件事，这就是单一职责原则，Single Responsibility Principle。*
>
> *这四个组件环环相扣，缺一不可。接下来我们逐个看代码实现。*

学生活动：跟随教师理解认证流程，记录四个组件的职责

AI工具操作：无

拍摄提示：教师与课件同框，教师手指依次指向流程的各个步骤。

预计字数：约200字，用时90秒

[18:30-20:00] LoginServlet实现讲解

画面：课件——"LoginServlet · 登录实现"页面，展示登录核心代码

教师动作：站在讲台前，指向代码关键行

教师台词：

> *首先看LoginServlet——这是认证环节的核心。*
>
> *代码很简单：从请求里取username和password，调用 `userService.authenticate()` 验证。如果验证通过——user不为null——就创建Session，`session.setAttribute("user", user)` 存一个user对象。*
>
> *注意，这里只存一个user对象，角色信息随User一起存入。不需要单独存role、displayName这些属性。为什么？因为如果你存了4个属性，万一其中一个更新了、其他的没同步，数据就不一致了。单一数据源原则。*
>
> *还有一个细节——登录成功用重定向 `sendRedirect`，失败用转发 `forward`。为什么？因为转发能保留request里的错误信息，重定向则能防止用户刷新浏览器重复提交表单。*

学生活动：跟随教师理解登录代码逻辑

AI工具操作：无

拍摄提示：教师与代码同框，教师手指指向关键代码行（setAttribute那行和重定向/转发那行）。

预计字数：约180字，用时90秒

[20:00-21:30] 登出与Session安全

画面：课件——"登出与Session安全"页面，展示安全登出代码和关键区别

教师动作：站在讲台前，语气着重强调区别

教师台词：

> *接下来看登出——这是大家课前认知偏差最大的知识点。*
>
> *安全的登出代码只有一行关键操作——`session.invalidate()`。注意是 `invalidate` 不是 `removeAttribute`。*
>
> *区别在哪？`removeAttribute("user")` 只删除了一个属性，但Session还活着。如果你之前还存了role、displayName等属性，它们全都还在。打个比方，这就像只是擦掉了名牌，但通行证还在你手上。*
>
> *而 `invalidate()` 是彻底销毁整个Session——所有属性一并清除，Session ID失效，Cookie作废。这才是真正的"退出登录"。*
>
> *这就是我们闯关第2关和Code Review要审查的核心问题之一。记住这个区别。*

学生活动：认真听讲，部分学生对照自己之前闯关中遇到的问题恍然大悟

AI工具操作：无

拍摄提示：教师正面中景，讲到两种方法区别时语气要有对比感，可用手势辅助区分。

预计字数：约180字，用时90秒

[21:30-22:30] JSP按角色显示菜单

画面：课件——"JSP按角色显示菜单"页面，展示动态菜单代码和核心原则

教师动作：站在讲台前，指向代码和原则框

教师台词：

> *最后看JSP视图层。这段代码用JSTL标签库按角色动态渲染菜单——只有当 `sessionScope.user.role` 等于ADMIN时，才显示"管理后台"入口。普通用户根本看不到这个链接。*
>
> *但是——（语气加重）这里有一个非常重要的原则：前端隐藏菜单只是用户体验优化，UX。真正的安全边界在后端Filter。*
>
> *为什么？因为即使你在JSP里把链接藏起来了，用户照样可以手动在浏览器地址栏输入URL直接访问。如果后端没有Filter拦截，这个隐藏就是纸老虎。*

> *所以完整方案等于前端隐藏加后端控制，两层防护缺一不可。*

学生活动：理解前后端防护的配合关系

AI工具操作：无

拍摄提示：教师指向课件上的"核心原则"框，语气在"纸老虎"处要有表现力。

预计字数：约160字，用时60秒

[22:30-24:00] 课程思政 + AI伦理反思

画面：课件——"课程思政：制度与秩序"页面 → "AI伦理反思"页面

教师动作：站在讲台中央，语气从技术转为思考

教师台词：

> *说到权限控制，RBAC的本质其实就是"制度先行、权责明晰"。每个系统——不管是技术系统还是社会系统——都需要规则和边界。认证回答"你是谁"，授权回答"你能做什么"，最小权限、默认拒绝。*
>
> *我们今天写的每一行权限控制代码，都在守护用户的隐私和权益。这是技术人员的职业责任，也是依法治网的基本要求。*
>
> *同样的道理，我们接下来要做的AI代码评审对战也会揭示一个问题——AI是强大的工具，但AI的能力边界在哪？技术决策的最终责任在人，这既是技术原则，也是职业伦理。*
>
> *好，核心概念讲完了。现在大家对认证、授权、Session和Filter有了完整认识，接下来我们用一个更刺激的方式来检验——代码评审对战！*

学生活动：认真听讲，思考技术与社会责任的关系

AI工具操作：无

拍摄提示：教师正面中近景，表情认真诚恳。思政部分语气要自然不生硬，不要有"念稿"的感觉。

预计字数：约200字，用时90秒

阶段四：AI代码评审对战（24:00-36:00，12分钟）

[24:00-25:00] Code Review Battle · 平台介绍与规则说明

画面：切换到Code Review Battle平台——对战首页

教师动作：回到讲台中央，语气变得兴奋有活力

教师台词：

> *好，同学们！核心概念已经掌握了。接下来我们进入一个更有挑战性的环节——Code Review Battle，代码评审对战！*
>
> *简单来说就是：你们vs AI，看谁能发现更多的安全漏洞！*
>
> *规则很简单：第1轮，你们各组自己审查代码，找出安全问题——5分钟，不准用任何AI工具。第2轮，我把同一段代码提交给AI，投影展示AI的审查结果——2分钟。第3轮，我们对比——你们找到了什么，AI找到了什么，谁更准、谁更全——展开讨论。*
>
> *这不是考试，这是对战！让我们看看人类和AI谁更厉害。*

学生活动：精神振奋，准备对战

AI工具操作：【Code Review Battle】展示对战平台首页，显示规则

拍摄提示：教师充满热情的正面中景。学生对"你们vs AI"表现出兴趣时，可切一个学生反应镜头。

预计字数：约180字，用时60秒

[25:00-26:00] 分组任务与待审查代码展示

画面：课件——待审查代码 `LogoutServlet.java` 全文 + 分组任务表

教师动作：指向屏幕上的代码，逐行简要说明

教师台词：

> *今天的审查对象是 `LogoutServlet.java`——登出功能的Servlet。屏幕上是完整代码。*
>
> *这段代码里已知存在4个安全漏洞，你们能找到几个？AI又能找到几个？*
>
> *三组的审查重点稍有不同：A组——认证组，重点看LoginServlet和LogoutServlet的Session管理是否安全；B组——授权组，重点看RoleBasedAuthFilter的权限过滤是否按角色控制；C组——视图一致性组，重点看index.jsp的菜单显示是否与权限一致。*
>
> *每组的审查报告要包含四项：问题位置、风险说明、对应知识点、修复建议。*
>
> *好，5分钟倒计时开始！*

学生活动：按组开始审查代码，记录发现的问题

AI工具操作：【Code Review Battle】平台显示待审查代码和计时器

拍摄提示：先全屏拍代码（确保每行清晰），然后拍分组任务表。教师说"开始"后，切到学生讨论的画面。

预计字数：约170字，用时60秒

[26:00-31:00] 第1轮 · 人工审查（5分钟）

画面：投影保持显示待审查代码，右下角显示倒计时

教师动作：离开讲台，在三个组之间走动巡视，低声观察和引导

教师台词：

> *（走到A组附近，低声）A组在看什么？Session那一行？对，想想 `removeAttribute` 和 `invalidate` 有什么区别——我们刚才核心概念讲过的。*
>
> *（走到B组附近，低声）B组找到什么了？Filter的问题？不错，想想它到底检查了什么，应该检查什么。*
>
> *（走到C组附近，低声）C组在讨论菜单？对，想想前端隐藏和后端控制是一回事吗？*
>
> *（走回讲台，大声）还有2分钟！各组确认一下你们的审查报告。记住——问题位置、风险说明、对应知识点、修复建议，四项都要有。*

> *（1分钟后）还有1分钟！*
>
> *（计时结束）好，时间到！请各组停笔。*

学生活动：各组围坐讨论，共同审查代码，记录发现的安全问题。不使用任何AI工具。

AI工具操作：无（纯人工审查阶段，严禁使用AI）

拍摄提示：（重要！）这是展示学生活动的核心环节。必须拍到：(1) 各组学生围坐讨论的全景；(2) 学生指着代码讨论的近景；(3) 学生在纸上/电脑上记录审查结果的画面；(4) 教师走动巡视指导的跟拍。辅机位在学生区域拍组内讨论，主机位跟拍教师走动。

预计字数：约150字（断续说出），用时300秒

[31:00-33:00] 第2轮 · AI审查（2分钟）

画面：切换到Code Review Battle平台——AI审查界面，教师将代码提交给AI

教师动作：回到教师机前，操作提交代码给AI，投影展示全过程

教师台词：

> *好，第2轮，轮到AI上场了！*
>
> *我现在把同一段LogoutServlet代码提交给AI进行安全审查。大家注意看AI的审查过程和输出结果。*
>
> *（提交代码，等待AI输出）*
>
> *好，AI出结果了。我们来看看AI发现了什么——*
>
> *第1个问题：`removeAttribute` 应改为 `invalidate()`，严重程度高。第2个：Filter未检查角色，严重程度高。第3个：JSP菜单未按角色显示，严重程度中。第4个：未设置Cache-Control 响应头，严重程度中。第5个：建议登出改用POST方法，严重程度低。*
>
> *AI一共找到了5个问题。你们找到了几个？我们马上来对比。*

学生活动：观看AI审查过程，记录AI发现的问题，与自己组的发现做对比

AI工具操作：【Code Review Battle】教师将代码提交AI → AI实时输出审查报告 → 报告展示在投影上

拍摄提示：全程屏幕录制，确保AI审查过程完整可见。AI输出结果时，教师逐条念出并指向对应内容。注意拍到学生观看AI结果时的表情反应。

预计字数：约180字，用时120秒

[33:00-34:30] 第3轮 · 各组汇报

画面：课件——各组汇报模板（三列对比表：A组/B组/C组）

教师动作：回到讲台中央，主持各组汇报

教师台词：

> *好，现在各组汇报。每组30秒，说三件事：你们发现了什么问题、对应什么知识点、修复建议是什么。*
>
> *A组先来！*

> ***（A组代表汇报，预计30秒）***

> *好的，A组抓住了LogoutServlet退出不彻底的问题——`removeAttribute`不等于`invalidate`。这是Session生命周期管理的核心知识点。非常好。*
>
> *B组！*

> ***（B组代表汇报，预计30秒）***

> *B组发现Filter只检查了是否登录，没有检查角色。这就是我们前面讲的Authorization的核心——光认证不够，还要授权。*
>
> *C组！*

> ***（C组代表汇报，预计30秒）***

> *C组发现了一个很容易被忽略的问题——登录后不管什么角色，首页都显示"管理后台"入口。前端隐藏按钮不等于安全控制。好，三组总共发现了3个关键问题。*

学生活动：各组代表站起来汇报，其他学生认真听取

AI工具操作：【Code Review Battle】教师在平台上记录各组发现

拍摄提示：拍汇报学生的正面中近景（站立发言），然后切教师点评的画面。三组轮流拍。

预计字数：约200字，用时90秒

[34:30-36:00] 人 vs AI · 对比分析 + 人机协同结论

画面：课件——"AI审查结果展示"页面 + "人 vs AI 对比表"

教师动作：站在屏幕旁，逐一对比，引导讨论

教师台词：

> *好，现在我们来做最关键的对比。AI找到了5个问题，你们找到了3个。看起来AI赢了？*
>
> *但我们仔细看——前三个问题：`removeAttribute` 应改为 `invalidate`——A组发现了。Filter未检查角色——B组发现了。JSP菜单未按角色显示——C组也发现了。关键漏洞，你们全部命中！*
>
> *第4个问题：未设置Cache-Control 响应头。这个你们漏掉了。AI说得对——如果用户退出登录后浏览器缓存了页面，别人只需要点"后退"按钮就可能看到敏感信息。AI帮我们发现了盲区。*
>
> *但第5个问题——AI建议把登出从GET改成POST。在我们当前的系统设计中，GET登出是完全合理的，AI按通用最佳实践检查，但它不了解我们的设计意图。所以这是一个AI误报——false positive。*
>
> *核心结论就一句话：**人机协同大于单独任何一方**。AI覆盖面广但缺乏业务判断，人理解上下文但可能遗漏细节。最佳模式是——AI先扫描，人做最终判断。*

学生活动：跟随教师分析，思考AI建议的合理性，记录核心结论

AI工具操作：【Code Review Battle】展示人机对比评分面板

拍摄提示：教师指着对比表讲解的中景。讲到"AI帮我们发现了盲区"时语气肯定，讲到"AI误报"时语气要自信坚定。

预计字数：约280字，用时90秒

阶段五：修复与验证（36:00-42:00，6分钟）

[36:00-37:00] 修复环节导入 + 权限过滤器修复代码

画面：课件——"第五部分：修复与验证"标题页 → "权限过滤器修复后代码"页面

教师动作：从对战模式自然过渡到分析模式，指向修复后代码

教师台词：

> *好，闯关做了，评审做了，漏洞我们都找到了。但光发现问题还不够，关键是要理解修复逻辑并验证效果。*
>
> *大家看这段修复后的RoleBasedAuthFilter代码——`@WebFilter("/admin/*")`拦截所有admin路径下的请求。核心逻辑是三层判断：Session为空，重定向到登录页；User不为空且角色是ADMIN，放行；其他情况返回403。*
>
> *注意防御性编程——`"ADMIN".equals(user.getRole())`而不是反过来写，防止getRole()返回null时的空指针异常。*

学生活动：观看修复代码，准备验证

AI工具操作：无

拍摄提示：教师与代码投影同框，确保代码清晰可读。

预计字数：约150字，用时60秒

[37:00-39:00] 验证测试(T1-T5) + 修复版演示

画面：课件——"最小测试清单"页面 → 浏览器切换到`demo-fixed.html`（修复版交互演示）

教师动作：先展示测试清单，然后在教师机上操作修复版演示，逐项执行测试

教师台词：

> *大家先看这个最小测试清单——T1到T5，5个测试场景覆盖了所有关键路径。*

> *现在我们来逐项验证。打开修复版演示。*
>
> *T1：未登录直接访问管理后台。（点击"模拟直接访问"）看——重定向到登录页。通过！*
>
> *T2：用tom登录后访问管理后台。（选tom登录）注意看——导航栏里没有"管理后台"入口了。即使手动输入URL呢？（模拟直接访问）返回403 Forbidden！通过！*
>
> *T3：admin登录后访问。（选admin登录）"管理后台"入口正常显示，进入管理面板正常。通过！*
>
> *T4：退出后再访问。（点击退出）Session已销毁，再访问直接跳转登录页。通过！*
>
> *T5：菜单一致性。admin看到管理入口，tom看不到。通过！*
>
> *5项测试全部通过！系统从"能登录"变成了"能安全控制访问"。*

学生活动：跟随教师观看验证过程，部分学生在自己电脑上同步操作

AI工具操作：无（使用交互演示页面验证）

拍摄提示：（重要！）以下画面必须清晰拍到：(1) 测试清单T1-T5表格；(2) tom登录后无"管理后台"入口；(3) tom直接访问被403拦截；(4) admin正常进入管理后台；(5) 退出后Session已销毁。

预计字数：约250字，用时120秒

[39:00-40:30] 修复前后对比

画面：课件——"修复前后对比"页面，四组件对比表 + 知识点映射

教师动作：指向对比表逐行讲解

教师台词：

> *大家看这个修复前后对比表——四个组件，每个都有变化。*
>
> *RoleBasedAuthFilter：从只检查isLoggedIn到检查user.getRole()是否为ADMIN——这是Authorization加RBAC。*

> *index.jsp：从所有人都显示管理入口到仅ADMIN显示——这是View Rendering加Session。*
>
> *LogoutServlet：从removeAttribute到invalidate——这是Session Lifecycle。*
>
> *LoginServlet：从冗余存储4个属性到只存一个user对象——这是Session Design的优化。*
>
> *每个修复都对应明确的知识点。遇到不理解的地方，随时可以向WebDev助教提问。*

学生活动：观看对比表，理解每处修复的知识点映射

AI工具操作：【WebDev助教】提醒学生可随时提问

拍摄提示：对比表全屏展示，教师在侧面逐行指向。确保表格内容清晰可读。

预计字数：约170字，用时90秒

[40:30-42:00] 学生自行操作验证

画面：投影保持修复前后对比表，学生在自己电脑上操作

教师动作：让学生自行操作体验，教师走动巡视

教师台词：

> *现在请大家在自己电脑上打开修复版和问题版演示页面，自行操作对比一遍。体验问题版和修复版的行为差异。*
>
> *特别注意用tom登录后的区别——问题版能进管理后台，修复版返回403。这就是一行Filter代码的价值。*
>
> *同时，如果你之前第2关还没通关的，现在可以带着这些知识回去继续挑战。给大家1分半的时间。*

学生活动：在自己电脑上对比操作问题版和修复版，部分学生回到WebSec平台继续闯关

AI工具操作：【WebSec挑战】部分学生继续闯关

拍摄提示：拍学生在电脑上操作的画面，穿插教师走动巡视镜头。

预计字数：约110字，用时90秒

阶段六：课堂总结（42:00-45:00，3分钟）

[42:00-43:00] 本节课数据回顾

画面：课件——"本节课数据回顾"页面（攻防闯关数据 + 评审对战数据 + WebDev助教数据）

教师动作：回到讲台中央，语气从实操转为反思总结

教师台词：

> *好，修复验证完成。我们来回顾一下今天这节课产生的数据。*
>
> *攻防闯关：第2关越权访问从最初的38%上升到了讲解后的80%以上，数据驱动干预效果立竿见影。*
>
> *评审对战：你们三组合计发现了3个关键漏洞，AI发现了5个但包含1个误报。人机协同后，总计确认了4个真实漏洞加1个AI独有的有效发现。*
>
> *WebDev助教的数据：课堂期间有12位同学实时向智能体提问，最热门的问题是"Filter和Servlet的区别"。*
>
> *这些数据会作为过程性评价的一部分，记录在你们每个人的学习档案中。*

学生活动：回顾自己的表现，查看自己在排行榜和评审对战中的成绩

AI工具操作：【全部工具】展示各平台的汇总数据

拍摄提示：以课件数据展示为主，教师侧面点评。数据页面要停留足够时间让观看者看清。

预计字数：约170字，用时60秒

[43:00-44:00] 三个核心收获

画面：课件——"三个核心收获"页面

教师动作：站在讲台中央，面向全班，语气沉稳有力

教师台词：

> *今天这节课，我希望大家记住三件事。*
>
> *第一——认证回答"你是谁"，授权回答"你能做什么"。Authentication不等于Authorization，登录成功不等于拥有所有权限。*
>
> *第二——RBAC加Filter，是后端权限控制的基本骨架。Filter是安全的第一道防线，前端隐藏加后端控制，才是完整方案。*
>
> *第三——人机协同大于单独任何一方。今天的评审对战证明了——AI帮我们发现了Cache-Control问题，但也产生了1个误报；WebSec闯关让每个人都亲手修复了漏洞。批判性判断，永远大于盲目采纳。*

学生活动：认真听讲，记录核心要点

AI工具操作：无

拍摄提示：教师正面中近景，表情认真。讲三个收获时可配合手势（比"一、二、三"）。

预计字数：约180字，用时60秒

[44:00-45:00] 课后任务布置 + 结课

画面：课件——"课后任务"页面

教师动作：走到讲台前方，语气轻松亲切

教师台词：

> *最后是课后任务。*
>
> *第一，完成WebSec挑战平台的第4关和第5关——XSS跨站脚本和综合BOSS关。排行榜一直开放，看谁能拿到第一名。*

> *第二，在你们的团队项目中实现权限控制模块——登录、登出、RBAC。TeamCoach会继续追踪每个人的贡献度，下周课前我会再展示周报。*
>
> *第三，有任何疑问，随时向WebDev助教提问，它24小时在线。*
>
> *第四，也是最重要的——写一份AI使用反思。这是必做作业。三个问题：AI在攻防闯关中给你的提示有帮助吗？你怎么判断是否采纳？Code Review Battle中AI的误报说明了什么？在你未来的开发工作中，AI代码审查应该扮演什么角色？*
>
> *（停顿，微笑）今天的课就到这里。希望大家以后做系统，不只追求"能运行"，更要追求"可验证、可控制、可信赖"。*
>
> *下课！Thank you, class!*

学生活动：记录课后任务，部分学生开始收拾物品

AI工具操作：无

拍摄提示：教师正面全景，学生开始收拾物品时可拍一个自然结束的氛围镜头。最后一句"Thank you, class"时教师可微微鞠躬，这是结课的标志性画面。

预计字数：约220字，用时60秒

附录A：全课时间轴总览

时间段	阶段	核心内容	AI工具	教师台词字数
0:00-0:30	开场	课题引入+教学目标	—	~100
0:30-1:30	导入	WebDev助教学情数据	WebDev助教	~200
1:30-2:30	导入	TeamCoach周报	TeamCoach	~180
2:30-4:00	导入	权限漏洞演示	—	~220
4:00-5:00	导入	核心问题提出	—	~180
5:00-7:00	闯关	WebSec平台规则(聚焦第2关)	WebSec挑战	~230
7:00-12:00	闯关	学生闯关+巡视	WebSec挑战+WebDev助教	~150
12:00-14:00	闯关	数据驱动干预	WebSec挑战	~170

时间段	阶段	核心内容	AI工具	教师台词字数
14:00-16:00	闯关	继续闯关+收尾	WebSec挑战	~100
16:00-17:00	精讲	认证与授权概念对比	—	~180
17:00-18:30	精讲	Session认证完整流程	—	~200
18:30-20:00	精讲	LoginServlet实现讲解	—	~180
20:00-21:30	精讲	登出与Session安全	—	~180
21:30-22:30	精讲	JSP按角色显示菜单	—	~160
22:30-24:00	精讲	课程思政+AI伦理	—	~200
24:00-25:00	对战	Battle规则说明	Code Review Battle	~180
25:00-26:00	对战	分组+代码展示	Code Review Battle	~170
26:00-31:00	对战	人工审查(5min)	—	~150
31:00-33:00	对战	AI审查(2min)	Code Review Battle	~180
33:00-34:30	对战	各组汇报	Code Review Battle	~200
34:30-36:00	对战	人vs AI对比+结论	Code Review Battle	~280
36:00-37:00	修复	修复导入+Filter代码	—	~150
37:00-39:00	修复	T1-T5测试验证	—	~250
39:00-40:30	修复	修复前后对比	WebDev助教	~170
40:30-42:00	修复	学生操作验证	WebSec挑战	~110

时间段	阶段	核心内容	AI工具	教师台词字数
42:00-43:00	总结	数据回顾	全部工具	~170
43:00-44:00	总结	三个核心收获	—	~180
44:00-45:00	总结	课后任务+结课	—	~220

教师台词总字数：约 4,960字
平均语速：约 110字/分钟（自然口语语速，含停顿和互动时间）

附录B：AI工具使用时间线

AI工具	使用时间点	使用方式	可见证据
WebDev助教	0:30-1:30	教师展示课前学情数据面板	投影上的热力图、TOP 3问题列表
TeamCoach	1:30-2:30	教师展示团队周报	投影上的贡献度对比图、风险预警
WebSec挑战	5:00-16:00	学生闯关(聚焦第2关)+实时数据大屏+教师干预	平台闯关界面、排行榜、通过率数据
WebDev助教	7:00-12:00	学生闯关中遇困难向智能体提问	学生屏幕上的智能体对话界面
Code Review Battle	24:00-36:00	人机对战：人工审查→AI审查→对比辩论	平台对战界面、AI审查报告、评分面板
WebDev助教	39:00-42:00	学生修复代码时向智能体提问	学生屏幕上的智能体回答
全部工具	42:00-43:00	教师展示各平台汇总数据	投影上的综合数据面板

附录C：拍摄关键画面清单

以下画面对于人工智能赛道评审至关重要，必须拍到：

1. **[0:00]** 教学目标页面快速展示

2. **[0:30]** WebDev助教后台学情数据面板（投影）
3. **[1:30]** TeamCoach团队周报页面（投影）
4. **[2:30-4:00]** Tom以普通用户身份进入管理后台的完整演示
5. **[5:00-7:00]** WebSec挑战平台关卡总览（第1、3关标记"课前完成"、第2关为课堂重点）
6. **[7:00-12:00]** 学生在电脑上闯关的画面（至少3个不同学生的镜头）
7. **[12:00]** 实时数据大屏显示"第2关通过率38%"
8. **[16:00-22:30]** 教师讲解核心概念（认证授权对比、Session流程、LoginServlet、登出安全、JSP菜单）
9. **[26:00-31:00]** 学生分组讨论审查代码的画面（至少2组）
10. **[31:00-33:00]** AI审查代码的完整过程（投影）
11. **[33:00-34:30]** 学生代表站立汇报的画面
12. **[34:30-36:00]** 人 vs AI对比表（投影）
13. **[36:00-37:00]** 权限过滤器修复后代码（投影）
14. **[37:00-39:00]** T1-T5测试全部通过的演示
15. **[39:00-40:30]** 修复前后对比表（投影）
16. **[42:00-43:00]** 各平台汇总数据展示

附录D：课件页面切换索引

按时间顺序列出应投影的课件/浏览器页面，方便录制时翻页：

时间	课件页面/切换目标	备注
0:00	Slide: 封面 "用户认证与权限控制"	
0:10	Slide: "教学目标"	快速展示
0:30	浏览器: WebDev助教教师仪表盘（或截图）	学情热力图+TOP3
1:30	浏览器: TeamCoach周报页面（或截图）	贡献度+风险预警
2:30	浏览器: `demo-problem.html` 问题版演示	选tom登录→管理后台
4:00	Slide: 核心问题大字 "能登录 ≠ 能安全控制访问"	
5:00	浏览器: WebSec挑战平台首页（或截图）	关卡总览(第1、3关课前完成)
5:30	Slide: "第2关 · 越权访问漏洞"	漏洞代码展示
7:00	浏览器: WebSec实时数据大屏	学生闯关中
12:00	数据大屏保持（教师指向通过率数据）	"第2关仅38%"

时间	课件页面/切换目标	备注
16:00	Slide: "认证与授权"	左右分栏对比
17:00	Slide: "Session认证完整流程"	四组件协同
18:30	Slide: "LoginServlet · 登录实现"	登录代码
20:00	Slide: "登出与Session安全"	invalidate vs removeAttribute
21:30	Slide: "JSP按角色显示菜单"	动态菜单+核心原则
22:30	Slide: "课程思政" → "AI伦理反思"	
24:00	浏览器: Code Review Battle平台首页（或截图）	对战规则
25:00	Slide: 待审查代码 LogoutServlet + 分组任务表	A/B/C三组分工
26:00	保持代码展示（学生审查中）	5min计时
31:00	浏览器: Code Review Battle AI审查界面（或截图）	AI实时输出
33:00	Slide: 各组汇报表	
34:30	Slide: 人 vs AI对比表 → 结论	
36:00	Slide: "权限过滤器修复后代码"	RoleBasedAuthFilter
37:00	Slide: "最小测试清单" → 浏览器: `demo-fixed.html`	T1-T5逐项验证
39:00	Slide: "修复前后对比"	四组件对比表
40:30	学生自行操作（投影保持对比表）	
42:00	Slide: "本节课数据回顾"	数据汇总
43:00	Slide: "三个核心收获"	
44:00	Slide: "课后任务"	
45:00	Slide: 结束页 "感谢聆听"	

附录E：应急预案

可能的问题	解决方案
WebSec挑战平台无法访问	用事先保存的平台截图替代，教师口述闯关流程
Code Review Battle平台故障	用课件中的代码截图，教师手动引导评审流程
WebDev助教响应缓慢	用事先截取的学情数据截图展示

可能的问题	解决方案
TeamCoach页面无法访问	用事先保存的周报截图展示
投影或网络故障	交互演示HTML文件为纯本地文件（`第十五讲交互演示/`），无需网络即可运行，可从U盘打开
学生电脑无法运行Java环境	使用HTML交互演示版代替：`demo-problem.html`（体验缺陷）和`demo-fixed.html`（体验修复），无需Tomcat
学生机器无法运行项目	教师机演示为主，学生在自己机器上跟做修复
AI审查输出异常	用事先保存的AI审查结果截图替代
录制设备故障	备用手机录制，至少保证音频完整

附录F：教师备忘

1. **语速控制**：每分钟100-115字，留出停顿和互动时间。不要赶进度。
2. **自然过渡**：各阶段之间不要有"下面进入第X环节"这种生硬过渡，用问题或数据自然衔接。
3. **眼神交流**：不要一直看屏幕，经常看向学生。提问时扫视全班。
4. **AI工具操作**：每次打开AI平台时，稍作停顿让镜头捕捉到工具界面。
5. **学生互动**：不要所有问答都自问自答，至少让3-5位学生发言。
6. **数据驱动**：每次展示数据后都要说明"这个数据告诉我什么/我据此做了什么决策"，体现数据驱动教学。
7. **双语要求**：关键术语第一次出现时给出中英文对照，后续可只说英文或只说中文。核心术语包括：Authentication、Authorization、Session、RBAC、Filter、Invalidate、Cache-Control。
8. **课程思政**：思政部分要自然融入核心概念讲解末尾，不要单独拎出来说"下面是思政环节"，这样会很生硬。
9. **核心概念精讲**：这是新增的独立阶段，是整节课知识传授的核心。讲解时语速可以稍慢，确保学生跟上。每个知识点都要与闯关中的实际问题建立关联。
10. **课前闯关衔接**：提到第1、3关时要肯定学生课前的成果，强调课堂聚焦第2关的原因——与本讲主题"权限控制"直接相关。